

手摸手之用户敏感信息展示脱敏

业务需求

将用户敏感信息脱敏展示到前端是出于保护用户隐私和信息安全的考虑。

敏感信息包括但不限于手机号码、身份证号、银行卡号等，这些信息泄露可能导致用户个人信息的滥用、身份盗用等严重问题。脱敏是一种常用的保护用户隐私的方式，它的目的是减少潜在的风险，同时保持一定的用户信息可读性。

比如咱们在选择用户信息以及展示选座信息时，用户证件号码的脱敏展示。

2023-08-11（周五）G35次北京南站（09:56开）——杭州东站（04:30到）

序号	席别	票种	姓名	证件类型	证件号码
1	商务座	成人票	万重山	中国居民身份证	1101*****1955
2	商务座	成人票	金来	中国居民身份证	1101*****6713

*如果本次列车剩余席位无法满足您的选座需求，系统将自动为您分配席位

🔊 选座咯

已选座0/2

窗

A

B

过道

C

窗

窗

A

B

过道

C

窗

本次列车，商务座余票4,一等座余票139,二等座余票807,

返回修改

确认

项目实战

技术选型

网上很多教程都是在说，通过 AOP、自定义注解和反射的方式完成字段脱敏功能。但是这种方式有点重量级且性能一般，遇到高并发场景存在性能瓶颈。

我举个循环嵌套的例子：

```
public class A {  
  
    private B b;  
}  
  
public class B {  
  
    private C c;  
}  
  
public class C {  
  
    private D d;  
}  
  
public class D {  
  
    @自定义注解  
    private String phone;  
}
```

如果按照反射的逻辑，就需要一层一层的解析嵌套对象直到找到自定义加密注解进行脱敏，性能可想而知。

为此，我想是否存在一种更为轻量级的脱敏技术实现？在网上搜索后，找到了一种比较符合我预期的实现方案：Jackson❖ 序列化方案。

实现思路

在 SpringMVC 返回数据时，通过默认的 Jackson 序列化器进行指定，替换为咱们已经包装后的序列化器，这样就能依赖现有解决方案，降低技术复杂度。

代码实现

定义手机号和证件号的 Jackson 自定义序列化器，并在对应需要脱敏的敏感字段上指定自定义序列化器。

1) 身份证号序列化器。

```
package org.opengoofy.index12306.biz.userservice.serialize;

import cn.hutool.core.util.DesensitizedUtil;
import com.fasterxml.jackson.core.JsonGenerator;
import com.fasterxml.jackson.databind.JsonSerializer;
import com.fasterxml.jackson.databind.SerializerProvider;

import java.io.IOException;

/**
 * 身份证号脱敏反序列化
 *
 * @公众号：马丁玩编程，回复：加群，添加马哥微信（备注：12306）获取项目资料
 */
public class IdCardDesensitizationSerializer extends JsonSerializer<String> {

    @Override
    public void serialize(String idCard, JsonGenerator jsonGenerator, SerializerProvider
serializerProvider) throws IOException {
        String phoneDesensitization = DesensitizedUtil.idCardNum(idCard, 4, 4);
        jsonGenerator.writeString(phoneDesensitization);
    }
}
```

2) 手机号序列化器。

```

package org.opengoofy.index12306.biz.userservice.serialize;

import cn.hutool.core.util.DesensitizedUtil;
import com.fasterxml.jackson.core.JsonGenerator;
import com.fasterxml.jackson.databind.JsonSerializer;
import com.fasterxml.jackson.databind.SerializerProvider;

import java.io.IOException;

/**
 * 手机号脱敏反序列化
 *
 * @公众号：马丁玩编程，回复：加群，添加马哥微信（备注：12306）获取项目资料
 */
public class PhoneDesensitizationSerializer extends JsonSerializer<String> {

    @Override
    public void serialize(String phone, JsonGenerator jsonGenerator, SerializerProvider
serializerProvider) throws IOException {
        String phoneDesensitization = DesensitizedUtil.mobilePhone(phone);
        jsonGenerator.writeString(phoneDesensitization);
    }
}

```

3) 敏感字段上自定义序列化器。

```

package org.opengoofy.index12306.biz.userservice.dto.resp;

import com.fasterxml.jackson.annotation.JsonFormat;
import com.fasterxml.jackson.databind.annotation.JsonSerialize;
import lombok.experimental.Accessors;
import org.opengoofy.index12306.biz.userservice.serialize.IdCardDesensitizationSerializer;
import org.opengoofy.index12306.biz.userservice.serialize.PhoneDesensitizationSerializer;

import java.util.Date;

/**
 * 乘车人返回参数
 *

```

```
* @公众号：马丁玩编程，回复：加群，添加马哥微信（备注：12306）获取项目资料
*/
@Data
@Accessors(chain = true)
public class PassengerRespDTO {

    /**
     * 证件号码
     */
    @JsonSerialize(using = IdCardDesensitizationSerializer.class)
    private String idCard;

    /**
     * 手机号
     */
    @JsonSerialize(using = PhoneDesensitizationSerializer.class)
    private String phone;
}
```

完成上述步骤后，前端调用 HTTP 请求获取数据时，SpringMVC 通过 Jackson 进行序列化数据时，操作证件号码和手机号两个字段就会采用咱们自定义的序列化器，完成敏感信息脱敏功能。

扩展思考

对接前端的敏感数据脱敏展示功能做到上面这些就已经实现了。但是总感觉哪里不对，因为咱们在购票服务中，下单接口会调用乘车人详细信息接口获取到手机号、证件号等信息保存入库。

如果我在后端服务里去调用乘车人的信息接口，那岂不是也是脱敏的？这样的话，存储到数据库的数据就不准确了，期望是真实的数据，但是实际是脱敏后的。

基于这种真实情况，目前 12306 中的做法是拆分一个新的实体，叫做 `PassengerActualRespDTO`，返回的信息是不脱敏的。其实本质上就是复制了一个乘车人实体，但是在证件号和手机号字段上不添加 `@JsonSerialize` 注解，以此满足业务需求。

更新: 2023-08-11 14:50:48

原文: <<https://www.yuque.com/magestack/12306/myl4gqx84bxyxmay>>